



ESCUELA COLOMBIANA DE INGENIERÍA JULIO GARAVITO

SEGURIDAD Y PRIVACIDAD DE TI

SGSI - ISO 27000

ENFOCADO EN

Introducción a la Norma ISO 27000

**ANDERSSON DAVID SÁNCHEZ MÉNDEZ
CRISTIAN SANTIAGO PEDRAZA RODRÍGUEZ**

PROFESOR:

JAVIER IVAN TOQUICA BARRERA

Lugar: Bogotá

Fecha: Febrero 20/2026



SGSI – ISO 27000

Estudiante: Andersson David Sánchez Méndez

Estudiante: Cristian Santiago Pedraza Rodríguez

Enfocado en: Introducción a la Norma ISO 27000

Fecha: Febrero 20, 2026

1. ¿Qué es un Sistema de Gestión de Seguridad de la Información (SGSI) según la ISO/IEC 27001?

Objetivo: Comprender el concepto y los beneficios de implementar un SGSI.

Un SGSI no es una solución tecnológica, sino un marco de gestión de procesos y gobierno orientado a preservar la tríada CIA mediante un enfoque de riesgos.

- Investigar los componentes de un SGSI.
Componentes del SGSI: Se compone de políticas, procedimientos, asignación de responsabilidades (gobierno), procesos de evaluación de riesgos y un conjunto de controles técnicos y administrativos.
- Explicar cómo un SGSI puede proteger la confidencialidad, integridad y disponibilidad de la información en una empresa.
Protección de la Tríada CIA:
 - **Confidencialidad:** El SGSI garantiza que el acceso a datos sensibles (ej. registros médicos o financieros) esté restringido mediante políticas de control de acceso y cifrado, permitiendo la visibilidad solo a entidades autorizadas.
 - **Integridad:** Asegura la exactitud de la información mediante controles de hashing, firmas digitales y gestión de cambios, evitando alteraciones no autorizadas en bases de datos críticas.
 - **Disponibilidad:** Protege el tiempo de actividad mediante planes de continuidad de negocio (BCP), recuperación ante desastres (DRP) y redundancia de infraestructura, garantizando que los servicios TI operen cuando el negocio lo requiera.

2. ¿Cuáles son los principios de la gestión de riesgos de la información bajo la ISO/IEC 27005?

Objetivo: Entender cómo el ciclo PDCA asegura la evolución constante del sistema de seguridad.

La ISO 27005 no prescribe una metodología única, sino que establece un proceso sistemático para que la seguridad sea **rentable y eficiente**, evitando la implementación de controles innecesarios.

- Definir los pasos clave en la identificación y evaluación de riesgos de seguridad.
Pasos clave:
 1. **Establecimiento del contexto:** Definir el alcance (ej. un centro de datos o un área de desarrollo).
 2. **Identificación de activos, amenazas y vulnerabilidades:** Listar qué tenemos, qué le puede pasar y qué debilidad permite que pase.
 3. **Análisis y Evaluación:** Determinar la probabilidad y el impacto para calcular el nivel de riesgo.
- Investigar cómo la ISO/IEC 27005 guía a las organizaciones en la toma de decisiones para mitigar riesgos.
Toma de decisiones: La norma guía a la organización para decidir si debe **Tratar** (aplicar control), **Tolerar** (aceptar el riesgo residual), **Transferir** (seguros o outsourcing) o **Terminar** (eliminar la actividad que causa el riesgo).

3. ¿Cómo el ciclo PDCA (Planificar, Hacer, Verificar, Actuar) apoya la mejora continua en un SGSI?

Objetivo: Entender cómo el ciclo PDCA asegura la evolución constante del sistema de seguridad.

El ciclo PDCA (Deming) es el motor que evita que el SGSI se vuelva estático y obsoleto frente a nuevas amenazas.

- Explicar el ciclo PDCA y su aplicación en la seguridad de la información.
 - **Plan (Planificar):** Se definen los objetivos de seguridad y se selecciona el catálogo de controles (SoA - Statement of Applicability).
 - **Do (Hacer):** Implementación técnica y operativa de los controles seleccionados (ej. configurar el firewall, capacitar al personal).
 - **Check (Verificar):** Auditorías internas y revisión por la dirección. Se mide si los controles son efectivos mediante KPIs (ej. "¿cuántas intrusiones detectó el IDS este mes?").
 - **Act (Actuar):** Acciones correctivas. Si un control falló, se ajusta la política o la tecnología para cerrar la brecha.
- Investigar ejemplos de cómo las organizaciones aplican este ciclo para mejorar sus controles de seguridad.
 - **Ejemplo 1: Gestión de Vulnerabilidades en Servidores Críticos**
Este ejemplo muestra cómo el ciclo permite pasar de una postura reactiva a una proactiva.
 - **Plan (Planificar):** Se define una política que establece que ninguna vulnerabilidad crítica debe permanecer sin parchear más de 48 horas en servidores de producción.
 - **Do (Hacer):** El equipo de operaciones despliega un sistema de gestión de parches (como WSUS o SCCM) y ejecuta las actualizaciones programadas.
 - **Check (Verificar):** Se realiza un escaneo de vulnerabilidades mensual con herramientas como Nessus o OpenVAS. El reporte revela que el 15% de los servidores Linux aún tienen vulnerabilidades de "Kernel Panic" de hace una semana.
 - **Act (Actuar):** Al detectar el fallo en el cumplimiento, la ingeniería ajusta el proceso integrando los parches en el pipeline de CI/CD para que se apliquen automáticamente en la creación de nuevas instancias, eliminando el error humano.
 - **Ejemplo 2: Control de Acceso y Gestión de Identidades (IAM)**
Este ejemplo se enfoca en el principio de "Privilegio Mínimo" mencionado en la lectura de Ross sobre Zero Trust.
 - **Plan (Planificar):** La organización establece que todo acceso a la base de datos de clientes debe requerir Autenticación de Múltiple Factor (MFA) y ser revisado trimestralmente.
 - **Do (Hacer):** Se implementa una solución de IAM (como Okta o AWS IAM) y se configuran los grupos de seguridad.
 - **Check (Verificar):** Durante una auditoría interna de registros (logs), se descubre que un ex-empleado del área de soporte aún tiene su cuenta activa y que varios desarrolladores tienen permisos de "Administrador" innecesarios.
 - **Act (Actuar):** Se automatiza el proceso de "Offboarding" integrando el software de RRHH con el Directorio Activo (AD) para deshabilitar cuentas instantáneamente al despido, y se

ejecuta un "User Access Review" para revocar permisos excesivos.

- **Ejemplo 3: Respuesta ante Incidentes de Ransomware**

Este ejemplo aplica la mejora continua tras un evento de seguridad real o simulado.

- **Plan (Planificar):** Se crea un Plan de Respuesta a Incidentes (IRP) que incluye copias de seguridad (backups) diarias inmutables y un tiempo de recuperación (RTO) de 4 horas.
- **Do (Hacer):** Se configuran tareas de respaldo en la nube con versionamiento y se realizan simulacros de ataque (Phishing/Ransomware).
- **Check (Verificar):** Se realiza una prueba de restauración de desastres. El equipo técnico descubre que, aunque los datos están respaldados, la velocidad de descarga desde la nube es muy lenta y el tiempo de recuperación real sería de 24 horas, no de 4.
- **Act (Actuar):** La organización decide invertir en una conexión directa (AWS Direct Connect o un enlace dedicado) o en un servidor de backup local (on-premise caching) para cumplir con el RTO exigido por el negocio.

4. ¿Qué son los controles del Anexo A de la ISO/IEC 27001 y cómo pueden aplicarse en una empresa?

Objetivo: Explorar los controles específicos que protegen los activos de información

- Investigar la función de los controles del Anexo A.
El Anexo A es el catálogo de herramientas de seguridad. Su aplicación debe ser basada en el riesgo para "añadir valor" en lugar de ser una carga burocrática.
- Elegir algunos controles y explicar cómo se aplican en escenarios empresariales.
 - **A.5.15 Segregación de Tareas:** Aplicación: El ingeniero que desarrolla el código no debe ser el mismo que tiene acceso a las llaves de producción para desplegarlo. Esto previene sabotajes o fraudes internos.
 - **A.8.10 Eliminación de Información:** Aplicación: Implementar procesos de borrado seguro (wiping) o destrucción física de discos duros antes de desecharlos, cumpliendo con normativas de protección de datos (GDPR/Ley 1581).
 - **A.8.5 Gestión de Autenticación Segura:** Aplicación: Implementar MFA (Multi-Factor Authentication) para todos los accesos administrativos a la infraestructura Cloud, mitigando el riesgo de robo de credenciales.

5. ¿Cuáles son los principales desafíos al implementar ISO 27001 en una organización y cómo superarlos?

Objetivo: Identificar soluciones a problemas reales al implementar un SGSI.

- Investigar barreras comunes como los costos, la resistencia interna y la falta de conocimiento técnico.
 - **Desafío 1: Resistencia al cambio y cultura organizacional.** La seguridad suele verse como un obstáculo a la agilidad.
 - **Desafío 2: Complejidad y costos de cumplimiento.** Implementar múltiples metodologías puede llevar a procesos ineficientes.
 - **Desafío 3:** Falta de personal calificado.

- Proponer estrategias prácticas para superar estos desafíos.
 - **Estrategia 1:** Involucrar a la alta dirección desde el inicio. Si el presupuesto y la política vienen "desde arriba", la adopción es mayor.
 - **Estrategia 2:** Adoptar un enfoque integrado. Utilizar marcos como ISO 27001 junto con NIST CSF para cubrir brechas de detalle sin duplicar esfuerzos.
 - **Estrategia 3:** Automatización de controles (DevSecOps) y capacitación continua del equipo de TI existente en estándares internacionales.

6. Genere una lista de todos los capítulos adicionales a ISO 27001, ISO27002 e ISO 27005 y su objetivo.

Norma	Propósito / Objetivo
ISO/IEC 27000	Glosario y fundamentos; proporciona el vocabulario estándar para la serie.
ISO/IEC 27017	Controles específicos para servicios en la Nube (Cloud Computing).
ISO/IEC 27018	Protección de datos personales (PII) en nubes públicas.
ISO/IEC 27031	Directrices para la adecuación de las tecnologías de información para la Continuidad del Negocio .
ISO/IEC 27032	Directrices para la Ciberseguridad (protección del ciberespacio).
ISO/IEC 27035	Gestión de incidentes de seguridad de la información.
ISO/IEC 27701	Extensión para la gestión de la Privacidad (PIMS).

REFERENCIAS

- International Organization for Standardization. (2022). *ISO/IEC 27001:2022 Information security, cybersecurity and privacy protection*.
- International Organization for Standardization. (2018). *ISO/IEC 27005:2018 Information technology — Security techniques — Guideline for information security risk management*.
- ISACA. (2024). *Adding Value With Risk-Based Information Security*. ISACA Journal, Volume 4.